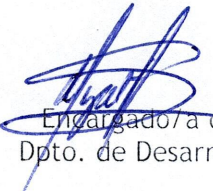
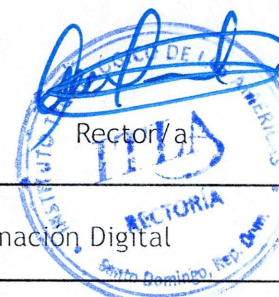


 INSTITUTO TECNOLÓGICO DE LAS AMÉRICAS Las Americas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE		CÓDIGO: DC-TI-11
Preparado Por:  Enchargado/a de Dpto. de Desarrollo	Revisado Por:  Director/a de Transformación Digital	Aprobado Por:  Rector/a	Fecha Emisión: 30/7/2026
Área Responsable	Dirección de Transformación Digital Dirección de Tecnología		Procesos Soporte o apoyo

POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

Contenido

1. OBJETIVO	3
2. ALCANCE	3
3. BASE LEGAL Y REFERENCIAS	4
4. DEFINICIONES	4
5. RESPONSABILIDADES	5
6. LINEAMIENTOS GENERALES DE LA POLÍTICA	8
7. EXCEPCIONES	19
8. INCUMPLIMIENTO	19
9. VIGENCIA	19
10. CONTROL DE REVISIONES	19

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

1. OBJETIVO

Establecer los lineamientos, controles y requisitos de seguridad que deberán aplicarse durante las fases de análisis, diseño, desarrollo, pruebas, implementación, mantenimiento y mejora continua de las soluciones de software desarrolladas por el Instituto Tecnológico de Las Américas (ITLA), con la finalidad de garantizar la confidencialidad, integridad, disponibilidad, calidad y protección de los activos de información institucionales.

La presente política busca asegurar que la seguridad sea incorporada durante todo el ciclo de vida del desarrollo de software, permitiendo reducir riesgos asociados a vulnerabilidades, accesos no autorizados, exposición indebida de información, pérdida de datos, interrupciones de servicios tecnológicos, modificaciones no autorizadas y cualquier condición que pueda afectar la operación institucional.

Asimismo, establece los controles necesarios para garantizar que las soluciones desarrolladas cumplan con criterios adecuados de seguridad, trazabilidad, mantenibilidad y protección del conocimiento tecnológico institucional.

2. ALCANCE

La presente política aplica a todos los sistemas, aplicaciones, servicios digitales, integraciones, plataformas y soluciones tecnológicas desarrolladas internamente por el Instituto Tecnológico de Las Américas (ITLA), independientemente del lenguaje de programación utilizado, la infraestructura tecnológica, la arquitectura, la metodología de desarrollo o el ambiente donde sean implementadas. Asimismo, es de cumplimiento obligatorio para el personal responsable del levantamiento y análisis de requerimientos, los equipos de desarrollo de software, el personal responsable de pruebas y aseguramiento de la calidad, los administradores de plataformas tecnológicas, los responsables de infraestructura tecnológica y de seguridad de la información, así como para los colaboradores internos o externos que participen en cualquier actividad relacionada con el ciclo de vida del desarrollo de software. En consecuencia, todos los desarrollos institucionales deberán cumplir los lineamientos establecidos en la presente política desde su planificación hasta su retiro o sustitución.

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

3. BASE LEGAL Y REFERENCIAS

La presente política se fundamenta en las normativas, estándares y buenas prácticas relacionadas con la gestión segura de tecnologías de información, incluyendo:

- Normas sobre Tecnologías de la Información y Comunicación (NORTIC) aplicables.
- Lineamientos del Sistema de Gestión de Seguridad de la Información (SGSI).
- Políticas internas relacionadas con seguridad de la información.
- Buenas prácticas para el Ciclo de Vida de Desarrollo Seguro de Software (Secure SDLC).
- Gestión de riesgos tecnológicos.
- Protección y administración de activos de información institucionales.

4. DEFINICIONES

Desarrollo Seguro de Software:

- Conjunto de prácticas, controles y medidas aplicadas durante el ciclo de vida del desarrollo de aplicaciones con el propósito de prevenir vulnerabilidades y proteger la información procesada.

Ciclo de Vida de Desarrollo de Software (SDLC):

- Proceso compuesto por las fases de planificación, análisis, diseño, construcción, pruebas, implementación, mantenimiento y mejora continua de una solución tecnológica.

Código Fuente:

- Conjunto de instrucciones, componentes y elementos desarrollados mediante lenguajes de programación que conforman una aplicación tecnológica.

Repositorio de Código Fuente:

- Plataforma o mecanismo utilizado para almacenar, administrar versiones y controlar modificaciones realizadas sobre el código fuente.

Ambiente de Desarrollo:

- Entorno utilizado para la construcción y modificación del software.

Ambiente de Pruebas:

- Entorno destinado a validar funcionamiento, seguridad y comportamiento de las aplicaciones previo a su puesta en producción.

Ambiente de Producción:

- Entorno donde las soluciones tecnológicas se encuentran disponibles para los usuarios finales.

Vulnerabilidad:

- Debilidad o condición existente en un sistema que puede comprometer la confidencialidad, integridad o disponibilidad de la información.

Información Sensible:

- Información institucional que por su naturaleza requiere controles especiales para evitar accesos o divulgación no autorizada.

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

5. RESPONSABILIDADES

5.1 Dirección de Transformación Digital

El Director de Transformación Digital será responsable de promover y supervisar la aplicación de los lineamientos establecidos en esta política, asegurando que las soluciones tecnológicas institucionales sean desarrolladas bajo criterios adecuados de seguridad, calidad y continuidad.

Sus responsabilidades incluyen:

- Velar por la implementación de prácticas de desarrollo seguro.
- Garantizar la gestión adecuada del ciclo de vida de las aplicaciones.
- Promover controles que permitan proteger los activos tecnológicos institucionales.

5.2 Departamento de Administración de Proyectos Digitales

El encargado del Departamento de Proyectos Digitales deberá incorporar los principios de desarrollo seguro durante la planificación, coordinación, seguimiento y cierre de los proyectos tecnológicos institucionales, asegurando que los requisitos de seguridad, calidad, continuidad y cumplimiento sean considerados durante todo el ciclo de vida del software.

Sus responsabilidades incluyen:

- Garantizar que los proyectos incorporen actividades de desarrollo seguro dentro de su planificación.
- Verificar que durante el ciclo de vida del proyecto se generen y mantengan los artefactos definidos por esta política.
- Coordinar la participación oportuna del Departamento de Desarrollo e Implementación de Sistemas, Departamento de Operaciones TIC, Seguridad de la Información y demás áreas involucradas durante el ciclo de vida del proyecto.
- Gestionar el seguimiento de riesgos, incidencias, vulnerabilidades y desviaciones que puedan afectar la seguridad del software.
- Validar que los criterios de aceptación del proyecto contemplen los controles de seguridad definidos por esta política.
- Coordinar con el Departamento de Operaciones TIC la planificación y ejecución de los despliegues, pases a producción, migraciones, actualizaciones y demás actividades de implementación que correspondan, garantizando una transición segura entre ambientes conforme a los procedimientos institucionales establecidos.
- Para toda implementación en ambiente de producción deberá elaborarse previamente un Plan de Implementación, el cual incluirá, como mínimo:
 - Actividades a ejecutar.
 - Responsables.

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

- Ventanas de mantenimiento cuando correspondan.
- Validaciones posteriores a la implementación.
- Plan de Contingencia o Rollback que establezca el procedimiento para revertir los cambios y restaurar el estado operativo anterior en caso de presentarse incidentes, fallas técnicas o resultados no esperados durante el proceso de implementación.
- Coordinar el cumplimiento de los entregables, hitos, criterios de aceptación y autorizaciones requeridas antes de la liberación del software hacia ambientes productivos.
- Coordinar el cierre formal del proyecto verificando la entrega de la documentación técnica, funcional, operativa y de seguridad correspondiente.
- Documentar, mantener actualizados y preservar los artefactos técnicos, funcionales, operativos y de seguridad que correspondan durante todo el ciclo de vida del software. La documentación requerida deberá ser proporcional a la naturaleza, complejidad, criticidad y alcance del proyecto, e incluirá, según corresponda, los documentos y artefactos definidos para cada fase del ciclo de vida del desarrollo de software (SDLC).

5.3 Departamento de Desarrollo de Software

El encargado del Departamento de Desarrollo e Implementación deberá aplicar los controles definidos durante el diseño, construcción, mantenimiento y mejora de las aplicaciones institucionales.

Sus responsabilidades incluyen:

- Aplicar buenas prácticas y estándares de programación segura durante el desarrollo, mantenimiento y mejora del software.
- Gestionar el código fuente mediante los repositorios institucionalmente autorizados.
- Utilizar repositorios institucionalmente autorizados.
- Ejecutar las pruebas técnicas que correspondan durante el proceso de desarrollo, incluyendo pruebas unitarias, de integración y demás validaciones técnicas necesarias para verificar el correcto funcionamiento del software antes de su entrega al proceso de Aseguramiento de la Calidad (QA).
- Gestionar la corrección de errores, defectos y vulnerabilidades identificadas durante el ciclo de vida del software.
- Coordinar con el Departamento de Administración de Proyectos Digitales la atención de los requerimientos, entregables, incidencias técnicas, correcciones y actividades necesarias durante el ciclo de vida del proyecto, así como brindar el soporte técnico requerido durante las etapas de implementación y estabilización del software.

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

5.4 Departamento de Ciberseguridad.

El Encargado del Departamento de Ciberseguridad deberá apoyar la identificación, evaluación y tratamiento de riesgos asociados al desarrollo de software.

Sus responsabilidades incluyen:

- Recomendar controles de seguridad aplicables.
- Evaluar riesgos tecnológicos cuando corresponda.
- Apoyar en la revisión de requisitos de protección de información.
- Dar seguimiento al tratamiento de vulnerabilidades identificadas.
- Verificar, cuando corresponda, que los controles de seguridad definidos durante el desarrollo sean implementados antes de la puesta en producción.

5.5 Departamento de Operaciones TIC

El Encargado del Departamento de Operaciones TIC deberá administrar y proteger la infraestructura tecnológica que soporta el desarrollo, pruebas, despliegue, operación y continuidad de las aplicaciones institucionales, garantizando ambientes seguros y controlados.

Sus responsabilidades incluyen:

- Administrar los ambientes de desarrollo, pruebas, preproducción y producción según corresponda.
- Gestionar la infraestructura tecnológica que soporta las aplicaciones institucionales, incluyendo servidores físicos y virtuales, bases de datos, redes, servicios cloud, centros de datos, MDF, IDF y demás componentes tecnológicos asociados.
- Implementar y mantener controles de seguridad sobre la infraestructura tecnológica.
- Gestionar el despliegue seguro de las aplicaciones hacia los ambientes institucionales autorizados.
- Garantizar la disponibilidad, integridad y continuidad de los servicios tecnológicos relacionados con las aplicaciones.
- Administrar los respaldos (Backups), restauración y recuperación de los componentes tecnológicos que soportan las aplicaciones institucionales.
- Gestionar la administración de bases de datos institucionales, garantizando su disponibilidad, integridad, confidencialidad y recuperación.
- Monitorear el desempeño de la infraestructura y apoyar la atención de incidentes relacionados con la operación de las aplicaciones.
- Coordinar con el Departamento de Desarrollo de Software, Ciberseguridad y Administración de Proyectos Digitales la implementación de cambios tecnológicos que puedan afectar la operación de las aplicaciones.

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	--	--

5.6 Función de Aseguramiento de la Calidad (QA)

La función de Aseguramiento de la Calidad (QA) será coordinada funcionalmente por el Departamento de Administración de Proyectos Digitales y ejecutada por el personal designado para realizar actividades de aseguramiento de la calidad, manteniendo independencia funcional respecto al Departamento de Desarrollo de Software, con el propósito de garantizar una evaluación objetiva, independiente y trazable de los productos desarrollados.

Sus responsabilidades incluyen:

- Planificar, coordinar y ejecutar las actividades de Aseguramiento de la Calidad (QA), en coordinación con el Departamento de Administración de Proyectos Digitales, conforme a los planes, cronogramas y criterios de aceptación definidos para cada proyecto.
- Verificar el cumplimiento de los requisitos funcionales, no funcionales, de seguridad y demás requisitos aplicables establecidos para el desarrollo de software.
- Ejecutar, según corresponda, las pruebas funcionales, de regresión, de aceptación, de rendimiento, de seguridad y cualquier otra prueba de aseguramiento de la calidad definida en el Plan de Pruebas del proyecto.
- Validar el cumplimiento de los criterios de aceptación antes de la liberación del software.
- Registrar, clasificar y dar seguimiento a los defectos, incidencias, no conformidades y hallazgos identificados durante el proceso de validación.
- Verificar que las observaciones, defectos, vulnerabilidades y no conformidades identificadas hayan sido corregidas o tratadas adecuadamente antes de recomendar la liberación del software.
- Emitir un resultado técnico de conformidad o no conformidad previa a la puesta en producción, cuando corresponda, el cual servirá como insumo para la decisión de liberación hacia producción por parte de las áreas competentes.

6. LINEAMIENTOS GENERALES DE LA POLÍTICA

6.1 Evaluación Inicial y Requisitos de Seguridad del Desarrollo

Todo proyecto de desarrollo de software deberá contemplar desde sus fases iniciales la identificación de los requisitos funcionales, tecnológicos y de seguridad necesarios para garantizar una implementación adecuada y alineada con las necesidades institucionales.

Durante la fase de análisis y diseño deberán evaluarse los aspectos relacionados con la seguridad de la información, operación tecnológica e impacto institucional de la solución a desarrollar.

Como mínimo deberán considerarse los siguientes aspectos:

- Objetivo y alcance del sistema.
- Procesos institucionales que serán soportados.
- Tipo de usuarios que utilizarán la solución.
- Clasificación y sensibilidad de la información gestionada.
- Nivel de exposición de la aplicación:
 - Uso interno.
 - Uso externo.
 - Servicio público.
- Tecnología y lenguaje de programación requerido.
- Infraestructura tecnológica necesaria.
- Integraciones con otros sistemas institucionales o externos.
- Requerimientos de disponibilidad y continuidad.
- Impacto sobre servicios tecnológicos existentes.
- Controles de seguridad aplicables.

Los sistemas considerados críticos o que procesen información sensible deberán contar con una evaluación de riesgos tecnológicos y de seguridad de la información previo a su implementación.

6.2 Seguridad desde el Diseño del Software

La seguridad deberá ser considerada como parte integral del ciclo de vida del desarrollo de software, incorporando controles desde las etapas iniciales de análisis, diseño y construcción de las soluciones tecnológicas.

Los equipos responsables deberán aplicar criterios de seguridad orientados a:

- Proteger la información procesada por las aplicaciones.
- Reducir riesgos asociados a vulnerabilidades.
- Evitar exposición innecesaria de datos institucionales.
- Garantizar controles adecuados de autenticación y autorización.
- Mantener la integridad y disponibilidad de los servicios desarrollados.

Las medidas de seguridad no deberán ser incorporadas únicamente como actividades posteriores al desarrollo, sino como un componente fundamental durante todo el ciclo de vida de la solución.

6.3 Gestión del Ciclo de Vida de Desarrollo Seguro de Software

Los desarrollos institucionales deberán gestionarse mediante un ciclo de vida estructurado que permita mantener control, trazabilidad y calidad durante todas las fases del proceso.

El ciclo de desarrollo deberá considerar como mínimo:

- Levantamiento y análisis de requerimientos.
- Diseño funcional y técnico.
- Desarrollo de la solución.

- Ejecutar, según corresponda, las pruebas unitarias, de integración, funcionales, de regresión, de aceptación, de rendimiento, de seguridad y cualquier otra prueba técnica o de aseguramiento de la calidad que resulte aplicable, de acuerdo con la naturaleza, complejidad, criticidad y riesgos del desarrollo de software, previo a su liberación o puesta en producción.
- Validación y aprobación.
- Implementación.
- Mantenimiento y mejora continua.

6.4 Control de Autenticación y Acceso en Aplicaciones

Las aplicaciones desarrolladas deberán implementar mecanismos seguros para gestionar la autenticación, autorización y control de acceso de los usuarios.

Se deberán aplicar controles relacionados con:

- Uso de mecanismos institucionales de autenticación cuando corresponda.
- Integración con servicios centralizados de identidad autorizados por la institución.
- Administración de usuarios mediante roles y permisos.
- Asignación de permisos conforme a las funciones requeridas.
- Aplicación del principio de mínimo privilegio.
- Protección adecuada de credenciales.

Los sistemas deberán garantizar que los usuarios únicamente tengan acceso a las funcionalidades e información necesaria conforme a sus responsabilidades.

Las credenciales utilizadas por las aplicaciones deberán protegerse mediante mecanismos seguros.

Queda prohibido almacenar contraseñas en texto claro dentro del código fuente, bases de datos, archivos de configuración o cualquier otro repositorio no autorizado.

6.5 Gestión Segura del Código Fuente

El código fuente generado como parte del desarrollo de soluciones tecnológicas institucionales deberá gestionarse mediante controles que garanticen su disponibilidad, integridad, confidencialidad y trazabilidad.

Para tales fines deberán aplicarse los siguientes criterios:

- Uso de repositorios autorizados por la institución.
- Control de versiones del código fuente.
- Registro histórico de modificaciones realizadas.
- Identificación de responsables de los cambios.
- Protección contra modificaciones no autorizadas.
- Administración adecuada de ramas o versiones de desarrollo cuando aplique.

Todo cambio realizado sobre el código fuente deberá poder ser identificado y asociado al responsable correspondiente mediante los mecanismos definidos por la institución.

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

6.6 Gestión de Componentes, Librerías y Dependencias

Los componentes externos utilizados durante el desarrollo de software deberán gestionarse adecuadamente para reducir riesgos derivados de vulnerabilidades conocidas o elementos no confiables.

Se deberán considerar los siguientes controles:

- Utilización de librerías, frameworks y componentes provenientes de fuentes confiables.
- Validación de versiones utilizadas.
- Actualización de componentes cuando corresponda.
- Identificación de componentes sin soporte o descontinuados.
- Evaluación de riesgos asociados a dependencias externas.

No deberán incorporarse componentes tecnológicos que representen riesgos identificados para la seguridad, estabilidad o continuidad de las soluciones institucionales.

6.7 Separación de Ambientes de Desarrollo, Prueba y Producción

La institución deberá mantener una separación adecuada entre los ambientes utilizados durante el ciclo de vida del desarrollo de software.

Como mínimo deberán contemplarse:

- Ambiente de desarrollo.
- Ambiente de pruebas o validación.
- Ambiente de producción.

La separación de ambientes deberá permitir:

- Reducir riesgos sobre los servicios productivos.
- Validar cambios antes de su publicación.
- Controlar accesos conforme al propósito de cada ambiente.
- Evitar modificaciones no autorizadas sobre sistemas en operación.

Las pruebas funcionales, técnicas, de seguridad y de calidad deberán realizarse en ambientes de desarrollo, pruebas o aseguramiento de la calidad (QA), utilizando información no productiva.

Cuando, por razones debidamente justificadas, sea necesario utilizar información proveniente de ambientes productivos, esta deberá anonimizarse o protegerse mediante controles técnicos y organizacionales que garanticen la confidencialidad, integridad y disponibilidad de la información, de conformidad con las políticas institucionales de seguridad de la información.

6.8 Gestión Segura de Bases de Datos

Las soluciones desarrolladas deberán incorporar controles orientados a proteger las bases de datos y la información almacenada.

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

Se deberán considerar como mínimo:

- Restricción de accesos conforme a las responsabilidades asignadas.
- Protección de información sensible.
- Uso adecuado de conexiones hacia bases de datos.
- Prevención de consultas inseguras.
- Control sobre modificaciones realizadas.
- Protección de configuraciones relacionadas con almacenamiento de información.

Los accesos administrativos hacia las bases de datos de producción, pruebas y demás ambientes institucionales deberán limitarse exclusivamente al personal autorizado.

6.9 Gestión de Vulnerabilidades en Aplicaciones

Las aplicaciones desarrolladas deberán ser evaluadas con la finalidad de identificar posibles vulnerabilidades que puedan afectar la seguridad de la información o la continuidad de los servicios tecnológicos.

Deberán considerarse riesgos asociados a:

- Fallos de autenticación.
- Errores en controles de autorización.
- Exposición indebida de información.
- Configuraciones inseguras.
- Manejo inadecuado de entradas de datos.
- Vulnerabilidades conocidas en componentes utilizados.

Las vulnerabilidades identificadas deberán ser analizadas, clasificadas y corregidas de acuerdo con el nivel de riesgo que representen para la institución.

6.10 Pruebas y Validación del Software

Previo a la implementación de una solución tecnológica en ambiente productivo, deberán ejecutarse las pruebas necesarias que permitan validar el cumplimiento de los requerimientos establecidos, la estabilidad del sistema y la correcta implementación de los controles definidos.

Las pruebas realizadas deberán contemplar, según corresponda:

- Validación de requerimientos funcionales.
- Validación de controles de seguridad implementados.
- Verificación de roles y permisos.
- Pruebas de integridad de información.
- Manejo adecuado de errores y excepciones.
- Validación de integraciones con otros sistemas.
- Verificación del comportamiento esperado de la aplicación.

Los resultados obtenidos durante las pruebas deberán ser documentados y utilizados como evidencia para la aprobación correspondiente previo a la liberación de la solución.

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

Ninguna solución tecnológica deberá ser promovida a producción sin haber completado las validaciones requeridas conforme al nivel de criticidad del sistema.

6.11 Gestión de Cambios e Implementaciones

Todo cambio realizado sobre aplicaciones institucionales deberá gestionarse mediante mecanismos formales de control de cambios previamente establecidos por la institución, los cuales podrán incluir procesos de gestión de solicitudes, evaluación técnica, aprobación por las instancias competentes, control de versiones mediante repositorios autorizados, registro de evidencias, pruebas previas a la implementación y autorización para su liberación a los ambientes correspondientes.

La implementación de cambios deberá considerar como mínimo:

- Identificación y descripción del cambio solicitado.
- Justificación de la modificación.
- Evaluación del impacto técnico y operativo.
- Validación de los ajustes realizados.
- Evidencia de pruebas correspondientes.
- Aprobación previa a su implementación cuando corresponda.
- Registro de la implementación realizada.

Los cambios sobre sistemas en producción deberán ejecutarse bajo criterios que permitan reducir riesgos de interrupción, pérdida de información o afectación de los servicios institucionales.

6.12 Gestión de Credenciales, Llaves y Secretos

Las aplicaciones institucionales deberán implementar mecanismos seguros para la gestión de contraseñas durante su creación, almacenamiento, transmisión, utilización, recuperación y cambio, evitando su exposición en texto plano, registros de eventos (logs), archivos de configuración, repositorios de código o cualquier otro medio no autorizado.

Los sistemas desarrollados por la institución deberán implementar mecanismos de autenticación robustos que impidan el uso de contraseñas débiles, triviales o ampliamente conocidas (por ejemplo: 123456, password, admin, qwerty, entre otras), promoviendo el uso de credenciales seguras mediante controles de complejidad, longitud, autenticación multifactor (MFA), protección contra ataques de fuerza bruta y demás mecanismos de seguridad definidos por la institución.

La definición, administración y control de las contraseñas deberán cumplir con lo establecido en la Política Institucional de Gestión de Contraseñas, así como con la Política Institucional de Ciberseguridad, la Política de Gestión de Identidades y Control de Acceso, cuando aplique, y los estándares y lineamientos técnicos adoptados por la institución.

Las contraseñas no deberán almacenarse ni transmitirse en texto plano y deberán protegerse mediante mecanismos criptográficos seguros aprobados por la institución.

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

Deberán protegerse adecuadamente:

- Contraseñas.
- Llaves de acceso.
- Tokens.
- Certificados digitales.
- Cadenas de conexión.
- Credenciales de servicios.
- Cualquier otro elemento utilizado para autenticación o autorización.

Queda prohibido incorporar o almacenar credenciales, contraseñas, llaves de acceso, tokens, certificados digitales, cadenas de conexión o cualquier otra información sensible directamente en el código fuente, archivos de configuración, scripts, historiales de versiones, repositorios de código o cualquier otro medio de almacenamiento no autorizado por la institución. Para estos fines deberán utilizarse mecanismos seguros de gestión de secretos aprobados por la institución.

Los mecanismos utilizados para almacenar y administrar este tipo de información deberán garantizar su protección contra accesos no autorizados.

Para la implementación de los controles definidos en esta sección, deberá observarse lo establecido en la **Política Institucional de Contraseñas Seguras**, la cual constituye el documento normativo de referencia para la gestión de credenciales, contraseñas, llaves y secretos utilizados por las aplicaciones institucionales.

6.13 Uso Seguro de Datos en Ambientes de Desarrollo

Las aplicaciones institucionales que procesen información durante las fases de desarrollo, pruebas u operación deberán implementar controles de seguridad que garanticen la confidencialidad, integridad y disponibilidad de la información utilizada.

En los ambientes de desarrollo y pruebas queda estrictamente prohibido el uso de datos personales o información sensible provenientes de entornos de producción, salvo que exista una autorización formal y se implementen mecanismos adecuados de anonimización, seudonimización, enmascaramiento u otras técnicas que mitiguen el riesgo de exposición de la información.

El tratamiento de datos personales durante el ciclo de vida del desarrollo de software deberá realizarse en estricto cumplimiento de la Política de Protección de Datos Personales vigente del Instituto Tecnológico de Las Américas (ITLA), disponible en el Site de Calidad en la Gestión, la cual establece los principios, responsabilidades y controles aplicables para la recolección, uso, almacenamiento, conservación, transmisión y eliminación de datos personales.

6.14 Registro de Eventos y Trazabilidad

Las soluciones tecnológicas desarrolladas deberán contemplar mecanismos que permitan registrar eventos relevantes para apoyar actividades de monitoreo, análisis, soporte, investigación y auditoría cuando sea requerido.

Según la criticidad y naturaleza del sistema, podrán registrarse eventos relacionados con:

- Accesos de usuarios.
- Actividades administrativas.
- Cambios relevantes realizados.
- Operaciones críticas.
- Errores del sistema.
- Eventos relacionados con seguridad.

Los registros generados deberán contar con controles adecuados para prevenir modificaciones no autorizadas y garantizar su disponibilidad conforme a los requerimientos institucionales.

6.15 Documentación, Mantenimiento y Continuidad del Software

Todo desarrollo institucional deberá contar con la documentación necesaria para facilitar su operación, mantenimiento, soporte y continuidad.

Los documentos y artefactos que conforman la documentación del desarrollo de software deberán generarse y mantenerse de acuerdo con el proceso aplicable y la fase del ciclo de vida del software, pudiendo incluir, entre otros, los siguientes:

Fase	Artefacto	Área Responsable
Planificación	Carta de Intención del Proyecto (Área Solicitante)	Área Solicitante
	Documento de Visión o Alcance	Administración de Proyectos Digitales
	Términos de Referencia (Cuando aplique)	Administración de Proyectos Digitales
	Acta Constitutiva del Proyecto	Administración de Proyectos Digitales
Análisis	Requerimientos Funcionales	Desarrollo e Implementación de Sistemas
	Requerimientos No Funcionales	Desarrollo e Implementación de Sistemas, Ciberseguridad y Operaciones TIC (según su ámbito de competencia)
	Diagramas de Casos de Uso	Desarrollo e Implementación de Sistemas
	Historias de Usuario (Metodologías Ágiles)	Administración de Proyectos Digitales

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

	Especificación de Casos de Uso (Metodologías Tradicionales)	Administración de Proyectos Digitales
	Matriz de Riesgos	Administración de Proyectos Digitales, con apoyo de las áreas técnicas involucradas
	Modelado de Amenazas (Threat Modeling)	Ciberseguridad
	Matriz de Trazabilidad	Administración de Proyectos Digitales
Diseño	Modelo de Arquitectura de Software en Cuatro Niveles (Modelo C4)	Desarrollo e Implementación de Sistemas
	Diagramas mediante Lenguaje Unificado de Modelado	Desarrollo e Implementación de Sistemas
	Modelo Entidad–Relación	Desarrollo e Implementación de Sistemas
	Registros de Decisiones Arquitectónicas	Desarrollo e Implementación de Sistemas
	Mockups o Wireframes	Desarrollo e Implementación de Sistemas
Desarrollo e Integración	Lista Priorizada de Funcionalidades del Producto (Product Backlog)	Desarrollo e Implementación de Sistemas
	Solicitud de Cambio	Administración de Proyectos Digitales
	Registro de Cambios	Desarrollo e Implementación de Sistemas
	Manual Técnico	Desarrollo e Implementación de Sistemas
Pruebas	Casos de Prueba	Administración de Proyectos Digitales (Aseguramiento de la Calidad)
	Evidencias y Resultados de Pruebas	Administración de Proyectos Digitales (Aseguramiento de la Calidad)
	Informes de Pruebas de Seguridad	Ciberseguridad
	Registro de Vulnerabilidades	Ciberseguridad
Despliegue	Guía de Despliegue	Desarrollo e Implementación de Sistemas y Operaciones TIC
	Bitácora de Liberaciones	Operaciones TIC
Operación y Mantenimiento	Manual de Usuario	Desarrollo e Implementación de Sistemas
	Plan de Respaldo y Recuperación	Operaciones TIC
	Lecciones Aprendidas	Administración de Proyectos Digitales
	Cualquier otro artefacto documental que la institución determine como necesario para	Administración de Proyectos Digitales

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	--	--

	garantizar la trazabilidad, mantenibilidad, seguridad, continuidad operativa y transferencia del conocimiento del software	
--	--	--

Los equipos responsables deberán mantener la documentación actualizada conforme evolucionen las soluciones tecnológicas.

Asimismo, deberán implementarse controles que permitan garantizar:

- Disponibilidad del código fuente.
- Continuidad del mantenimiento.
- Transferencia adecuada de conocimiento.
- Capacidad de recuperación ante eventos que afecten la disponibilidad del software.

6.16 Protección del Código Fuente, Propiedad Intelectual y Confidencialidad

El código fuente, componentes desarrollados, documentación técnica, diseños, arquitectura de aplicaciones, estructuras de datos, configuraciones y cualquier otro elemento generado durante el ciclo de vida del desarrollo de software serán considerados activos de información institucionales del Instituto Tecnológico de Las Américas (ITLA), por lo cual deberán ser protegidos contra accesos, divulgación, modificación, extracción, distribución, publicación o uso no autorizado.

Todo colaborador interno o externo que participe en actividades relacionadas con análisis, diseño, desarrollo, pruebas, implementación, mantenimiento o administración de soluciones tecnológicas deberá cumplir con los compromisos de confidencialidad establecidos por la institución, conforme a la naturaleza de sus funciones y al nivel de acceso otorgado sobre los activos tecnológicos institucionales.

Para garantizar la protección del código fuente y los activos relacionados con el desarrollo de software, deberán considerarse los siguientes controles:

- El código fuente deberá permanecer bajo custodia de repositorios, plataformas o mecanismos autorizados por la institución.
- Los repositorios utilizados para almacenar código fuente deberán mantenerse bajo propiedad, administración y control institucional.
- No deberá almacenarse código fuente institucional en cuentas personales, repositorios externos no autorizados, dispositivos personales, servicios en la nube particulares o cualquier medio no aprobado por la institución.
- La copia, descarga, transferencia, publicación o distribución del código fuente fuera de los mecanismos autorizados deberá contar con la aprobación correspondiente.

 Las Américas Institute of Technology	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

- Los colaboradores internos o externos con acceso al código fuente, documentación técnica o información sensible asociada al desarrollo deberán estar sujetos a acuerdos de confidencialidad, cláusulas contractuales o compromisos equivalentes establecidos por la institución.
- La información relacionada con arquitectura tecnológica, lógica de negocio, modelos de datos, integraciones, configuraciones, credenciales, mecanismos internos de funcionamiento y documentación técnica deberá ser manejada bajo criterios adecuados de confidencialidad.
- Los permisos otorgados sobre repositorios deberán responder únicamente a las necesidades de participación dentro del proyecto correspondiente.
- Deberá mantenerse trazabilidad sobre las modificaciones realizadas al código fuente mediante mecanismos de control de versiones.
- El intercambio de información técnica relacionada con desarrollos institucionales deberá realizarse únicamente mediante canales autorizados por la institución.
- Cualquier extracción del código fuente para fines de respaldo, migración, auditoría, soporte u otra necesidad institucional deberá realizarse bajo controles previamente definidos.
- El acceso otorgado al código fuente, documentación técnica o cualquier componente relacionado con soluciones desarrolladas por la institución no representa transferencia de propiedad, autorización de reutilización, distribución, comercialización ni uso fuera de los fines institucionales autorizados.
- La administración de accesos relacionados con repositorios, herramientas de desarrollo y plataformas tecnológicas deberá realizarse conforme a los procedimientos institucionales establecidos para la gestión de usuarios, roles y privilegios.

6.17 Diseño Seguro de Bases de Datos

Las bases de datos utilizadas por las aplicaciones institucionales deberán diseñarse, implementarse y mantenerse aplicando principios de seguridad, integridad, consistencia, trazabilidad y mantenibilidad durante todo el ciclo de vida del desarrollo de software.

El diseño de esquemas relacionales, la definición de tablas, columnas, llaves primarias, llaves foráneas, restricciones, índices, auditoría, nomenclatura, normalización y demás elementos estructurales deberán cumplir con lo establecido en el Estándar General de Diseño y Refactorización de Esquemas de Base de Datos, vigente y disponible en el **Site de Calidad en la Gestión**, el cual constituye el

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11 VERSIÓN: 0
---	---	---

documento técnico institucional de referencia para el diseño, creación, revisión y refactorización de bases de datos relacionales.

El incumplimiento de dicho estándar deberá ser debidamente justificado, documentado y aprobado conforme al proceso de gestión de excepciones definido por la institución.

7. EXCEPCIONES

Cualquier excepción relacionada con los controles establecidos en la presente política deberá estar debidamente documentada, justificada y evaluada por las áreas responsables correspondientes.

Toda excepción deberá considerar:

- Descripción de la condición que impide el cumplimiento del control.
- Justificación técnica o institucional.
- Evaluación del riesgo asociado.
- Controles compensatorios cuando correspondan.
- Responsable autorizado para su aprobación.
- Periodo de vigencia de la excepción cuando aplique.

Las excepciones no deberán comprometer la seguridad, confidencialidad, integridad o disponibilidad de los activos tecnológicos institucionales.

8. INCUMPLIMIENTO

El incumplimiento de los lineamientos establecidos en la presente política podrá generar riesgos asociados a vulnerabilidades de seguridad, exposición de información institucional, pérdida de integridad de los sistemas, indisponibilidad de servicios tecnológicos o uso indebido de activos institucionales.

Todo incumplimiento identificado deberá ser gestionado conforme a los procedimientos internos establecidos por la institución y las medidas administrativas correspondientes.

9. VIGENCIA

La presente política entrará en vigor a partir de su aprobación formal por las autoridades competentes del Instituto Tecnológico de Las Américas (ITLA).

Los lineamientos establecidos deberán ser considerados para los nuevos desarrollos de software y para las modificaciones, actualizaciones o mantenimientos realizados sobre las soluciones tecnológicas existentes.

10. CONTROL DE REVISIONES

La presente política deberá ser revisada como mínimo cada dos (2) años con la finalidad de garantizar su actualización y alineación con las necesidades institucionales, cambios

	POLÍTICA DE DESARROLLO SEGURO DE SOFTWARE	CÓDIGO: DC-TI-11
		VERSIÓN: 0

tecnológicos, normativas aplicables, buenas prácticas de seguridad de la información y evolución de los procesos de desarrollo de software.

De igual manera, podrá ser revisada antes del periodo establecido cuando existan cambios significativos en:

- Normativas relacionadas con tecnologías de información.
- Requerimientos institucionales.
- Arquitecturas tecnológicas utilizadas.
- Procesos internos de desarrollo.
- Riesgos identificados asociados a la seguridad del software.

Toda modificación realizada sobre esta política deberá ser gestionada conforme al proceso institucional establecido para la actualización, aprobación y control documental.